

Fecha: 26/8/2026

1. Historia de Usuario

Como: usuario registrado del Portal Corporativo Aurora

Quiero: iniciar sesión con mi usuario y contraseña

Para: acceder a mi panel de trabajo mientras el sistema protege mi cuenta bloqueándola temporalmente tras 3 intentos fallidos consecutivos.

2. Nivel de Riesgo Global: MEDIO

El requerimiento es funcionalmente acotado (un único módulo de autenticación, sin integración con sistemas externos ni impacto financiero directo), lo que reduce el riesgo comparado con cambios transversales. Sin embargo, involucra lógica de seguridad crítica de estado (contador por cuenta, bloqueo temporal de 15 minutos, expiración) cuyo mal manejo de condiciones límite (tercer intento exacto, concurrencia de solicitudes, zona horaria del timestamp de desbloqueo) puede dejar cuentas expuestas a fuerza bruta o bloquear usuarios legítimos. El impacto afecta a todos los usuarios registrados del portal corporativo, lo cual eleva el riesgo operativo si falla. La reversibilidad es alta (no hay pérdida de datos ni cambios irreversibles), y no hay dependencias externas mencionadas, por lo que no se justifica un nivel ALTO.

3. Criterios de Aceptación

- **CA_1:** Dado un usuario registrado con credenciales válidas, Cuando envía el formulario de login, Entonces el sistema inicia sesión, redirige al Dashboard y muestra el nombre del usuario en la esquina superior derecha.
- **CA_2:** Dado un usuario que ingresa una contraseña incorrecta para un correo existente, Cuando envía el formulario, Entonces el sistema muestra "Usuario o contraseña incorrectos" y permanece en la pantalla de login sin conceder acceso.
- **CA_3:** Dado un usuario que ingresa un correo no registrado, Cuando envía el formulario, Entonces el sistema muestra el mismo mensaje genérico "Usuario o contraseña incorrectos" sin indicar que el usuario no existe.
- **CA_4:** Dado un usuario con 2 intentos fallidos previos consecutivos, Cuando registra un tercer intento fallido, Entonces la cuenta queda bloqueada y el sistema muestra un mensaje explícito de bloqueo indicando 15 minutos de espera.
- **CA_5:** Dado que una cuenta está bloqueada, Cuando se intenta iniciar sesión con la contraseña correcta durante el periodo de bloqueo, Entonces el sistema deniega el acceso y muestra el mensaje de bloqueo, no el de credenciales incorrectas.
- **CA_6:** Dado un usuario con 1 o 2 intentos fallidos previos, Cuando inicia sesión exitosamente, Entonces el contador de intentos fallidos de esa cuenta se reinicia a 0.
- **CA_7:** Dado que una cuenta bloqueada ha superado los 15 minutos desde el bloqueo, Cuando el usuario intenta iniciar sesión nuevamente, Entonces el sistema evalúa las credenciales normalmente (ya no muestra el mensaje de bloqueo) y, si son correctas, concede acceso.
- **CA_8:** Dado que una cuenta se desbloquea tras los 15 minutos, Cuando el usuario falla el primer intento post-desbloqueo, Entonces el sistema lo cuenta como intento 1 de un nuevo ciclo (no arrastra el conteo previo al bloqueo).

4. Reglas de Negocio

- **RN_1:** El sistema bloquea la cuenta automáticamente al registrar el tercer (3°) intento fallido consecutivo de login sobre esa cuenta.

- **RN_2:** La duración del bloqueo es fija en 15 minutos desde el momento en que se activa, tras los cuales el sistema debe volver a aceptar intentos sin intervención manual.
- **RN_3:** El conteo de intentos fallidos es por cuenta (identificada por el correo corporativo), independiente del dispositivo, navegador o dirección IP de origen.
- **RN_4:** El mensaje de error ante credenciales inválidas es único e invariable ("Usuario o contraseña incorrectos") sin distinguir entre usuario inexistente y contraseña incorrecta, para evitar enumeración de cuentas.
- **RN_5:** Un login exitoso reinicia el contador de intentos fallidos consecutivos de la cuenta a cero, sin importar cuántos intentos fallidos previos tuviera (siempre que no haya alcanzado el bloqueo).
- **RN_6:** Mientras la cuenta esté en estado de bloqueo activo, ningún intento de autenticación es evaluado como válido, incluso si las credenciales ingresadas son correctas.

5. Riesgos

- **R_1:** Alto | El bloqueo no se activa exactamente en el tercer intento fallido (off-by-one) por error de conteo o de comparación ($\geq$ vs $>$). | La cuenta queda expuesta a fuerza bruta indefinida, incumpliendo el objetivo central del requerimiento.
- **R_2:** Medio | El temporizador de desbloqueo no libera la cuenta correctamente pasados los 15 minutos (por manejo incorrecto de zona horaria, reloj del servidor o job de expiración). | Usuarios legítimos quedan bloqueados indefinidamente, generando incidentes de soporte y pérdida de productividad.
- **R_3:** Medio | El mensaje de error expone información diferenciada entre usuario inexistente y contraseña incorrecta por inconsistencia entre frontend y backend. | Facilita ataques de enumeración de cuentas corporativas válidas.
- **R_4:** Bajo | Solicitudes de login concurrentes o en paralelo sobre la misma cuenta generan condiciones de carrera en el contador de intentos. | El contador podría no bloquear a tiempo o bloquear de forma inconsistente bajo ataques automatizados rápidos.
- **R_5:** Bajo | No se especifica bloqueo o limitación por IP/dispositivo, solo por cuenta. | Un atacante podría distribuir intentos entre múltiples cuentas sin activar ningún bloqueo individual (ataque de rociado de contraseñas no cubierto por este requerimiento).

6. Impactos

- **MÓDULO_AUTENTICACIÓN** | Se modifica la lógica de validación de credenciales para incorporar conteo de intentos fallidos por cuenta y verificación de estado de bloqueo antes de evaluar la contraseña.
- **GESTIÓN_DE_SESIÓN** | El flujo de login exitoso debe reiniciar el contador de intentos y mantener la redirección al Dashboard con el nombre del usuario, sin cambios en la sesión ya iniciada.
- **UI_LOGIN:** La pantalla de login requiere nuevos estados visuales/mensajes: error genérico de credenciales y mensaje explícito de cuenta bloqueada con tiempo restante.
- **PERSISTENCIA_DE_DATOS:** Se requiere almacenar por cuenta el contador de intentos fallidos, el estado de bloqueo y el timestamp de inicio/fin del bloqueo (nuevo campo o tabla asociada al usuario).
- **SOPORTE_Y_OPERACIONES:** Posible aumento de solicitudes a mesa de ayuda por bloqueos legítimos (usuarios que olvidan su contraseña), sin mecanismo de desbloqueo manual descrito en el requerimiento.

7. Escenarios QA Sugeridos

- **ESC_1:** Positivo | Login exitoso con credenciales válidas | Usuario: usuario.valido@aurora.com / Contraseña: Correcta123*. Verificar redirección al Dashboard y nombre visible en esquina superior derecha.
- **ESC_2:** Negativo | Login fallido por contraseña incorrecta con usuario existente | Usuario: usuario.valido@aurora.com / Contraseña: Incorrecta999. Verificar mensaje genérico y permanencia en login.
- **ESC_3:** Negativo | Login fallido por usuario inexistente | Usuario: noexiste@aurora.com / Contraseña: Cualquiera123. Verificar que el mensaje sea idéntico al de ESC_2, sin indicar que el usuario no existe.
- **ESC_4:** Borde | Bloqueo exacto al tercer intento fallido consecutivo | Realizar 2 intentos fallidos con usuario.valido@aurora.com, luego un tercer intento fallido. Verificar que tras el tercero (no antes) se active el bloqueo y el mensaje de 15 minutos.
- **ESC_5:** Borde | Intento con contraseña correcta durante bloqueo activo | Provocar bloqueo (3 fallos) y luego intentar con la contraseña correcta antes de que expiren los 15 minutos. Verificar que se deniegue el acceso mostrando el mensaje de bloqueo, no el de credenciales incorrectas.
- **ESC_6:** Positivo | Reinicio de contador tras login exitoso | Realizar 2 intentos fallidos, luego 1 intento exitoso, luego 2 intentos fallidos nuevamente. Verificar que la cuenta NO se bloquee (el contador se reinició a 0 tras el éxito, por lo que va en su segundo fallo del nuevo ciclo).
- **ESC_7:** Borde | Expiración del bloqueo tras 15 minutos | Provocar bloqueo, esperar (o simular vía backend/mock de tiempo) exactamente 15 minutos y 1 segundo, luego intentar login con credenciales correctas. Verificar que se conceda acceso normalmente.
- **ESC_8:** Negativo | Intentos fallidos tras expiración de bloqueo cuentan como nuevo ciclo | Tras expirar un bloqueo previo, provocar 2 intentos fallidos. Verificar que la cuenta NO se bloquee todavía (debe requerir 3 nuevos fallos consecutivos, no arrastrar el conteo anterior).
- **ESC_9:** Negativo | Campos vacíos o mal formados no deben contar como intento válido de fuerza bruta indefinido | Enviar el formulario con campo de contraseña vacío. Verificar comportamiento del sistema (mensaje de validación) y si cuenta o no como intento fallido consecutivo.